كتاب تدريبي عملي | إصدار مبني على المستودع

# KubeMart
# منصة Kubernetes
# للتجارة الإلكترونية

دليل عربي متدرج لفهم التطبيق والشبكات والتخزين والأمان والاعتمادية والمراقبة والنشر

المستودع: mhmdhmdbdh2050/kubemart-kubernetes-platform

المرجع: master بعد دمج PR #1

24 أكتوبر 2026

# فهرس المحتويات

1. نظرة عامة
2. العمارة ومسارات الطلب
3. دليل الملفات
4. الإعداد والنشر
5. شرح تقني عميق
6. قراءة الإعدادات
7. التحقق واستكشاف الأعطال
8. الأمان والاعتمادية
9. سجل المخاطر والعيوب
10. خارطة التحسين
11. اختبار المعرفة
12. مفتاح الإجابات

> **طريقة الدراسة:** ابدأ بالفصلين 1 و2، اقرأ الملفات المشار إليها، ثم حاول النشر في sandbox. أجب عن الفصل 11 قبل قراءة مفتاح الفصل 12.

# الفصل 1 — نظرة عامة

KubeMart مشروع تعليمي يربط متجرًا بسيطًا بواجهة API وقاعدة بيانات، ويستخدم Kubernetes لتجربة النشر والتوجيه والتخزين والأمان والمراقبة.

## ما الذي يفعله التطبيق؟

واجهة HTML/CSS/JavaScript تعرض كتالوجًا وسلة، وتتيح تسجيل الحساب وطلب إنشاء order. FastAPI يتحقق من الحساب والجلسة، ويقرأ الأسعار والمخزون من PostgreSQL، ثم ينشئ الطلب ويخصم الكميات ضمن transaction. لا توجد بوابة دفع أو شحن أو إدارة مخزون تجارية متكاملة.

| التقنية | الموقع | الدور |
|---|---|---|
| Python 3.12 / FastAPI / Uvicorn | app/backend/ | REST API والمصادقة والتحقق والاتصال بقاعدة البيانات. |
| PostgreSQL 16 / psycopg | k8s/statefulsets/ | المستخدمون والجلسات والمنتجات والطلبات والمخزون. |
| pwdlib / Argon2 / EmailStr | app/backend/requirements.txt | تجزئة كلمة المرور والتحقق من البريد. |
| NGINX unprivileged | app/frontend/ | يخدم الصفحة ويمرر /api/ إلى FastAPI. |
| Kubernetes | k8s/ | تشغيل Pods وServices وIngress وPVC والسياسات والمهام. |
| AWS EBS CSI | k8s/storage/ | توفير Persistent Volume عند وجود Driver/IAM مناسب. |
| Helm / Prometheus / Grafana / Loki / Fluent Bit | k8s/monitoring/ وk8s/helm/ | مخطط NGINX تدريبي وقيم إعداد للمراقبة والسجلات. |
| GitHub Actions / Kubeconform | .github/workflows/ci.yml | compile وبناء الصور والتحقق من manifests. |

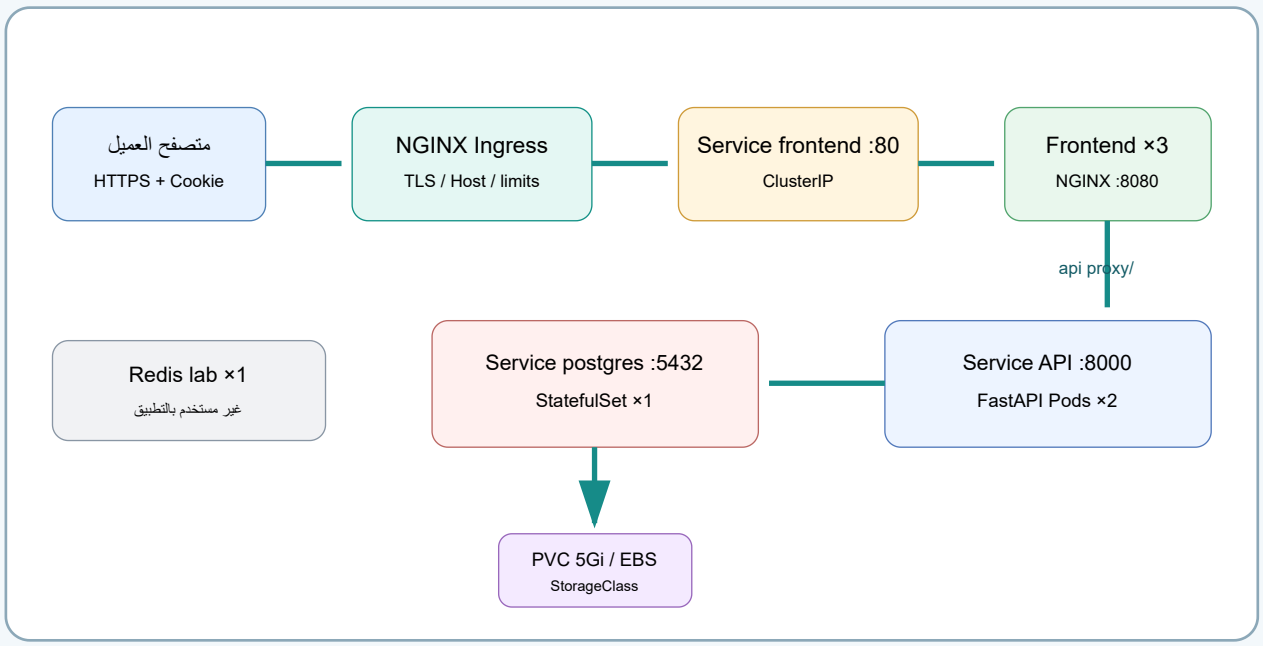
**نطاق المستودع:** لا توجد فيه Terraform أو Docker Compose أو ملفات إنشاء VPC/EC2/EKS. README يصف مختبر Kubernetes/AWS، لكنه لا يثبت حالة الكلاستر أو نشر كل مكون. قيم Helm لا تعني أن chart منشور.

يوجد معجم المصطلحات في نهاية الدليل للرجوع السريع.

# الفصل 2 — العمارة وتدفق الطلب

## مخطط التطبيق

العمارة كما تمثلها ملفات المشروع




Redis مثال مستقل؛ الأسهم الأخرى تمثل المسار المقصود في manifests.

المخطط لا يثبت وجود موارد حية في الكلاستر. Controller يقرأ Ingress ثم يوجه إلى الواجهة.

## تدفق تحميل المتجر

1. DNS يحل اسم نطاق يملكه المشغل إلى نقطة دخول Ingress.
2. Ingress controller يقرأ host/path وTLS في `kubemart-ingress.yaml`.
3. Ingress يرسل إلى frontend Service port 80، التي تختار Pods بوسم `app=frontend`.
4. Service targetPort 8080 يوصل إلى NGINX الذي يخدم `index.html`.
5. JavaScript يطلب `/api/products`. NGINX يمررها إلى API Service :8000، وFastAPI يستعلم PostgreSQL.

## تدفق الحساب والطلب

```
POST /api/auth/register {customer_name,email,password}
FastAPI validates -> Argon2 hash -> PostgreSQL users
random token -> HttpOnly/Secure/SameSite=Strict cookie
sessions table stores SHA-256(token), expiry 7 days

POST /api/orders {items:[{product_id,quantity}]}
verify hashed cookie/session -> SELECT products FOR UPDATE
validate stock + calculate total on server
insert order/items + decrement stock in one transaction
```

# الفصل 3 — دليل الملفات

## التطبيق والتوثيق

| المسار | المسؤولية | التحقق أو الخطر |
|---|---|---|
| `README.md` | عمارة وتعليمات وأوامر نشر وأمن. | قارنه بالـmanifests؛ Phase docs تاريخية. |
| `app/backend/main.py` | FastAPI، DB schema، auth/session، المنتجات والطلبات. | مصدر السلوك؛ يلزم اختبارات API/DB. |
| `app/backend/requirements.txt` | قيود إصدارات التبعيات. | لا lockfile؛ البناء غير ثابت بالكامل. |
| `app/backend/Dockerfile` | Python 3.12-slim، pip، UID 10001، Uvicorn. | build context app/backend. |
| `app/frontend/index.html` | واجهة وسلة وتسجيل حساب وطلب عبر fetch. | ليس حد أمان؛ API يتحقق مجددًا. |
| `app/frontend/nginx.conf` | 8080، proxy، headers/CSP، health/، api static. | upstream DNS/port mismatch يكسر API. |
| `app/frontend/Dockerfile` | صورة NGINX non-root ونسخ الصفحة والصور. | يتطلب images/ ويوافق port 8080. |
| `.github/workflows/ci.yml` | Kubeconform، Docker build، compile. | لا اختبارات وظيفية أو نشر. |
| `docs/phase-05-external-access.md` | سجل HTTP/NodePort تاريخي. | لا يثبت TLS الحالي. |
| `docs/phase-06-reliability.md` | سجل probes/HPA/PDB وrollouts. | بعض القيم تاريخية. |
| `docs/phase-07-workloads.md` | init/sidecar/Job تدريبي. | الـJob لا يقرأ طلبات حقيقية. |
| `docs/phase-09-security-rbac.md` | RBAC على Kubernetes API. | مختلف عن حساب المتجر. |
| `docs/phase-10-application-authentication.md` | توثيق الجلسات وCookie/schema. | قارنه مع main.py عند التغيير. |
| `.gitignore` | استثناء secrets والملفات المؤقتة. | افحص git status قبل commit. |

## موارد النشر الأساسية

| المسار | الدور | ملاحظات التحقق |
|---|---|---|
| `k8s/namespace/namespace.yaml` | إنشاء namespace kubemart. | طبق أولًا. |
| `k8s/config/postgres-secret.example.yaml` | قالب مفاتيح DB. | لا تطبق placeholders أو ترفع قيمًا حقيقية. |
| `k8s/storage/kubemart-storageclass.yaml` | EBS CSI, Retain, WaitForFirstConsumer. | يتطلب driver/IAM/AWS. |
| `k8s/storage/postgres-pvc.yaml` | طلب 5Gi ReadWriteOnce. | Retain ليس backup. |
| `k8s/services/postgres-service.yaml` | Headless DNS :5432. | يرتبط بـStatefulSet. |
| `k8s/statefulsets/postgres-statefulset.yaml` | Postgres 16 وSecret وPVC وprobes، نسخة واحدة. | لا backup manifest. |

| | | |
|---|---|---|
| `k8s/app/backend.yaml` | API×2 و8000: Service<br>Secret/security/probes و. | يتطلب ECR وDB credentials. |
| `k8s/deployments/frontend-deployment.yaml` | 3 :8080 nonroot/read-only Pods. | emptyDir للمسارات القابلة للكتابة. |
| `k8s/services/frontend-service.yaml` | 80 → 8080. | selector app=frontend. |
| `k8s/ingress/kubemart-ingress.yaml` | Host/TLS/rate limit إلى frontend. | example host يحتاج استبدالًا. |
| `k8s/security/network-policy-example.yaml` | 8080: Ingress namespace → frontend. | يعتمد على CNI. |
| `k8s/security/api-ingress-policy.yaml` | 8000: frontend → API. | labels يجب أن تطابق Pods. |
| `k8s/security/postgres-ingress-policy.yaml` | 5432: API → DB. | لا يحدد egress. |

## مختبرات ومساندات

| المسارات | الغرض والحدود |
|---|---|
| k8s/autoscaling/frontend-hpa.yaml; k8s/policies/frontend-pdb.yaml; k8s/security/resource-quota.yaml | HPA CPU 60% min3/max6؛ PDB min2؛ حدود namespace. HPA يحتاج metrics API/requests. |
| k8s/security/*role*.yaml; *rolebinding*.yaml | قراءة Pods وNamespaces عبر RBAC؛ ليس auth لمتجر. |
| k8s/scheduling/* | node selector/affinity/taints/tolerations؛ القيود قد تسبب Pending. |
| k8s/examples/* | Pods/init/sidecar؛ مختبرات منفصلة. |
| k8s/jobs/* | Job/CronJob محاكاة، لا DB؛ Cron كل دقيقة. |
| k8s/deployments/redis-deployment.yaml; k8s/services/redis-service.yaml | Redis مستقل، appendonly off؛ التطبيق لا يستخدمه. |
| k8s/helm/nginx-lab/* | Helm chart تعليمي لـNGINX؛ CI يستثنيه. |
| k8s/monitoring/*-values.yaml | قيم Prometheus/Grafana/Loki/Fluent Bit، لا تثبت install أو service DNS. |
| k8s/storage/postgres-storage-check.yaml; k8s/workloads/kubemart-node-agent.yaml | تجربة تخزين وworkload إضافي؛ راجع صلاحيات/أثر التطبيق. |
| docs/screenshots/* | لقطات واجهة ومراقبة تاريخية لا تثبت النشر الحالي. |
| k8s/helm/nginx-lab-values.yaml; k8s/security/security-context-pod.yaml | قيم Helm إضافية ومثال Pod مستقل لـsecurityContext. |
| k8s/config/frontend-config.yaml | ConfigMap يقدم APP_NAME/ENVIRONMENT/API_URL؛ لا يستهلكه frontend Deployment الحالي. |

> لا يوجد مجلد tests. CI يترجم Python ويبني الصور ويفحص بعض YAML، لكنه لا يختبر تدفق الحساب والطلب.

# الفصل 4 — الإعداد والنشر

> **التكلفة:** EC2/EBS/Load Balancer/NAT/Monitoring قد تكلف مالًا. استخدم sandbox، وافهم التكاليف والصلاحيات. لا تحذف PVC قبل حفظ البيانات.

### المتطلبات

Kubernetes وDocker/ECR/AWS CLI، EBS CSI driver/IAM، DNS/TLS، ingress-nginx، kubectl. إنشاء AWS network/cluster غير موجود بالمستودع.

## 1. الفحص والتنزيل

```
git clone https://github.com/mhmdhmdbdh2050/kubemart-kubernetes-platform.git
cd kubemart-kubernetes-platform
kubectl config current-context
kubectl cluster-info
kubectl get nodes -o wide
kubectl get storageclass
```

تأكد من context المقصود وحالة العقد. هذه أوامر قراءة.

## 2. Namespace وSecrets

```
kubectl apply -f k8s/namespace/namespace.yaml
kubectl create secret generic postgres-secret -n kubemart \
  --from-literal=POSTGRES_DB='kubemart' \
  --from-literal=POSTGRES_USER='kubemart_app' \
  --from-literal=POSTGRES_PASSWORD='REPLACE_WITH_LONG_RANDOM_VALUE'

# after receiving certificate for your domain
kubectl create secret tls kubemart-tls -n kubemart \
  --cert=/path/to/fullchain.pem --key=/path/to/private-key.pem
```

قيم توضيحية فقط. استخدم secret manager وتشفير at-rest وRBAC؛ Base64 ليس تشفيرًا. لا تحفظ ملف Secret حقيقي في Git.

## 3. بناء الصور إلى ECR

```
REGISTRY=YOUR_AWS_ACCOUNT_ID.dkr.ecr.us-east-1.amazonaws.com
aws ecr get-login-password --region us-east-1 | docker login --username AWS --password-stdin "$REGISTRY"
docker build -f app/backend/Dockerfile -t "$REGISTRY/kubemart-api:v3" app/backend
docker push "$REGISTRY/kubemart-api:v3"
docker build -f app/frontend/Dockerfile -t "$REGISTRY/kubemart-frontend:v1" app/frontend
docker push "$REGISTRY/kubemart-frontend:v1"
```

استبدل YOUR_AWS_ACCOUNT_ID برقم حساب AWS الخاص بك، وتأكد من ملكية registry/repositories/tag. الإعداد يشير إلى Secret `ecr-pull-secret` أو اعتمد هوية عقدة. استخدم tags فريدة وimage digests.

## 4. قاعدة البيانات

```
kubectl apply -f k8s/storage/kubemart-storageclass.yaml
kubectl apply -f k8s/storage/postgres-pvc.yaml
kubectl apply -f k8s/services/postgres-service.yaml
kubectl apply -f k8s/statefulsets/postgres-statefulset.yaml
kubectl rollout status statefulset/postgres -n kubemart
kubectl get pvc,pv -n kubemart
```

WaitForFirstConsumer يؤخر الربط لحين معرفة جدولة Pod. PVC Pending قد يعني driver/IAM/AZ.

## 5. API والواجهة والشبكة

```
kubectl apply -f k8s/app/backend.yaml
kubectl apply -f k8s/deployments/frontend-deployment.yaml
kubectl apply -f k8s/services/frontend-service.yaml
kubectl apply -f k8s/security/network-policy-example.yaml
kubectl apply -f k8s/security/api-ingress-policy.yaml
kubectl apply -f k8s/security/postgres-ingress-policy.yaml
kubectl apply -f k8s/ingress/kubemart-ingress.yaml
kubectl rollout status deployment/kubemart-api -n kubemart
kubectl rollout status deployment/frontend -n kubemart
```

استبدل host؛ جهز TLS وECR credentials؛ أثبت دعم NetworkPolicy في CNI. HPA والمراقبة لها متطلبات تثبيت منفصلة.

## 6. التحقق

```
kubectl get pods,svc,ingress,pvc -n kubemart -o wide
kubectl get endpointslices -n kubemart
kubectl get events -n kubemart --sort-by=.metadata.creationTimestamp
kubectl logs deployment/kubemart-api -n kubemart
curl -I https://YOUR_DOMAIN/
curl https://YOUR_DOMAIN/api/products
```

المتوقع: Pods Ready وendpoints موجودة وPVC Bound وTLS صالح وJSON منتجات. لم تنفذ هذه الأوامر على كلاستر المستخدم؛ هذه نتائج متوقعة فقط.

## تنظيف

راجع الكلفة والبيانات أولًا. إيقاف CronJob لا يعني حذف PVC؛ لا تحذف namespace إلا بعد تأكيد أن بيانات DB قابلة للتخلص.

# الفصل 5 — شرح تقني عميق

## Image وContainer

Dockerfile يحدد base image والملفات والـuser والـcommand؛ image قالب والحاوية نسخة تشغيل. Backend على Python 3.12-slim وUID 10001؛ NGINX unprivileged على 8080. Kubernetes يسحب الصور ولا يبنيها.

## Service وIngress

Service يختار Pods عبر labels ويقدم DNS ثابتًا. EndpointSlices تعرض الأهداف الجاهزة. Ingress Controller يطبق قواعد Ingress؛ وجود المورد لا ينشئ DNS/TLS أو public load balancer.

### التخزين

PostgreSQL StatefulSet نسخة واحدة مع PVC 5Gi. Retain يقلل الحذف الآلي للقرص، لكنه ليس backup ولا يثبت الاستعادة. يلزم backup منفصل وتجربة restore.

### الجلسات

1. التسجيل يتحقق EmailStr وكلمة مرور 12-128 حرفًا.
2. Argon2 hash يذهب لـusers.
3. token عشوائي في Cookie؛ PostgreSQL تحفظ SHA-256 digest وانتهاء الجلسة.
4. كل api/auth/me/ وPOST orders يتحقق من session غير منتهية؛ logout يحذفها.
5. لا reset password أو verification أو refresh rotation.

### المخزون والمعاملة

API يجمع الكميات، يقفل صفوف المنتجات بـ`FOR UPDATE` بترتيب IDs، يتحقق من stock ويحسب السعر من DB ثم يدرج order/items ويخصم المخزون ضمن transaction. هذا يقلل oversell؛ لا يمنع retry من إنشاء طلب ثان (لا idempotency key).

## Health probes

| Probe | المسار | المعنى |
|---|---|---|
| API liveness | /live | التطبيق يرد، لا يتصل DB. |
| API readiness | /health | يفحص DB بـ SELECT 1؛ الفشل يبعد Pod عن traffic. |
| frontend | / | يثبت NGINX/الصفحة فقط. |
| Postgres | pg_isready | يختبر قبول اتصال محلي لا backup. |

## HPA/PDB/Quota وCI

HPA CPU 60% من requests على frontend min3/max6، ويتطلب metrics API وPDB minAvailable2 يحمي من بعض requests. الإخلاء الطوعي فقط. Quota يحد مجموع الموارد/Pods. GitHub Actions يعمل على push وpull_request؛ compile/build/Kubeconform فقط، بلا tests/scans/deploy.

# الفصل 6 — فهم الإعدادات

## ربط labels وports

```
# Pod template
labels:
  app: frontend
containerPort: 8080

# Service
selector:
  app: frontend
ports:
  - port: 80
    targetPort: 8080

# Ingress
service:
  name: frontend
  port:
    number: 80
```

اختلاف labels يؤدي إلى endpoints فارغة، واختلاف targetPort يفشل الاتصال. افحص selector وEndpointSlices والمنفذ الفعلي.

## Secret injection

```
env:
  - name: POSTGRES_PASSWORD
    valueFrom:
      secretKeyRef:
        name: postgres-secret
        key: POSTGRES_PASSWORD
```

يوصل السر لـAPI/Postgres فقط. لا تضعه في image أو README. Secret لا يعني أن etcd مشفر تلقائيًا؛ قلل RBAC وفعل encryption at rest.

## SecurityContext

```
runAsNonRoot: true
runAsUser: 101
readOnlyRootFilesystem: true
allowPrivilegeEscalation: false
capabilities:
  drop: ["ALL"]
```

frontend يركب emptyDir لـcache/tmp. اختبر UID والمسارات في الصورة. backend UID 10001.

## TLS وHelm

Host في rules وTLS متطابق، والـSecret في namespace kubemart ويحوي شهادة للنطاق. Values ملفات إدخال إلى chart لا موارد منشورة؛ راجع `helm template` ونسخة chart قبل install.

# الفصل 7 — التحقق واستكشاف الأعطال

## شجرة القرار

```
الموقع لا يعمل؟ DNS/TLS -> Ingress/controller -> frontend endpoints
يعمل و API يفشل؟ /api/products -> NGINX upstream -> API endpoints
API لا Ready؟ /health يعتمد DB -> Postgres service/Pod -> PVC/Secret
الاتصال محجوب؟ labels/policy -> CNI enforcement -> DNS/ports
```

## أوامر مفيدة

```
kubectl get pods,svc,ingress,pvc -n kubemart -o wide
kubectl get endpointslices -n kubemart
kubectl get events -n kubemart --sort-by=.metadata.creationTimestamp
kubectl describe pod POD -n kubemart
kubectl logs deployment/kubemart-api -n kubemart --previous
kubectl logs deployment/frontend -n kubemart
kubectl describe pvc postgres-pvc -n kubemart
kubectl describe ingress kubemart-ingress -n kubemart
```

| العرض | التحقيق | إجراء محتمل |
|---|---|---|
| ImagePullBackOff | describe/events، image tag، pull secret/ECR IAM. | صحح credentials/repo/tag. |
| PVC Pending | PVC events، CSI driver، IAM/AZ. | صحح provisioner/topology. |
| API 503 | health، DB service/DNS/secret/logs/. | أصلح dependency ولا تجعل liveness يفحصها. |
| واجهة 200 وAPI timeout | NGINX logs، API endpoints، policy/DNS. | طابق upstream/labels/ports أو policy. |
| 401 دائم | DevTools Set-Cookie، HTTPS/host/path، /auth/me. | استخدم TLS ولا توقف Secure علنًا. |
| HPA لا يعمل | HPA events، kubectl top، metrics API/requests. | أصلح metrics واضبط requests. |
| Pod Pending | events، affinity/taints/selector/quota. | صحح placement أو السعة. |
| Policy غير فعالة | CNI ونمط allow/deny في بيئة آمنة. | وفر CNI ينفذ NetworkPolicy. |

ابدأ بجمع state/events/logs، ثم غيّر شيئًا واحدًا. الأوامر لا تعني أن نجاحًا فعليًا تحقق على كلاستر المستخدم.

# الفصل 8 — الأمن والاعتمادية

| المجال | الموجود | الفجوة |
|---|---|---|
| Authentication | orders، digest، session cookie، Argon2 تتطلب جلسة. | لا tests/reset/verification/rotation. |
| TLS | Ingress يشير إلى Secret. | example domain وشهادة HTTPS غير مثبتة. |
| CSRF | SameSite Strict وOrigin check. | اختبارات خلف proxy لازمة. |
| Login abuse | rate limit عام في Ingress. | لا حماية auth مخصصة/alerts مثبتة. |
| Secrets | secretKeyRef والواجهة بلا DB password. | external secret manager، encryption، least privilege/rotation. |
| Pod security | API/frontend non-root/read-only/dropped caps. | Postgres/Redis/examples أقل تشددًا؛ images غير مقفلة كلها. |
| Network | سياسات ingress. | فعالية CNI غير مثبتة وegress مفتوح. |
| HA/DR | frontend3/API2. | Postgres1 ولا backup/restore/HA. |
| Monitoring | Helm values. | release/version/alerts/ingestion غير متحقق. |
| CI/dependencies | compile/build/schema. | لا tests/scans/deploy، ولا lockfile/digests كاملة. |

## شروط قبل الإنتاج

1. اختبارات auth/CSRF/checkout/تزامن.
2. Domain/TLS وrenewal وفحص خارجي.
3. NetworkPolicy allow/deny مثبتة على CNI الفعلي.
4. PostgreSQL HA/backup/restore مشفر مع RPO/RTO.
5. Secret manager وتشفير etcd وRBAC محدود.
6. Rate limits لـlogin/reset/verification وتنبيهات.
7. Metrics/alerts/log retention/runbooks.
8. Supply-chain scan وload test ومراجعة كلفة.

# الفصل 9 — سجل المخاطر والعيوب

الشدة تقديرية للإنتاج؛ المخاطر المشروطة تحتاج تحققًا من الكلاستر. لا تعني أن live environment فُحص.

| ID/الشدة | الدليل والأثر | الحل والتحقق | |
|---|---|---|---|
| F-01 شبكة/عالٍ مشروط | README يذكر Flannel وNetworkPolicies. إذا لم يطبقها CNI فقد لا تعزل الحركة. | تحقق من CNI واختبر allow/deny؛ استخدم CNI يدعم policy enforcement. | |
| F-02 بيانات/عالٍ | Postgres replicas=1 ولا backup/restore automation. | Managed DB أو HA وPITR وrestore مجرب وفق RPO/RTO. | |
| F-03 migrations/ متوسط | main.py ينفذ DDL عند start لنسختين API، بلا versioned migration. | Migration job/tool وحيد مع lock/backup وتوافق rollout. | |
| F-04 auth/متوسط | لا throttling موثق لمسارات login/register ولا lockout/alerts. | rate limits خاصة، audit/alerts واختبار. | |
| F-05 supply chain/ متوسط | requirements ranges وimage tags مثل postgres:16. | SBOM، digests، lock/hash وscan/signing. | |
| F-06 testing/عالٍ قبل الإنتاج | لا tests؛ CI لا يختبر auth/DB/races. | pytest integration/E2E/concurrency مع DB test service. | |
| F-07 service discovery/متوسط مشروط | NGINX upstream DNS ثابت؛ تبدل ClusterIP بعد service recreation قد يحتاج reload. | اختبر في staging ووثق resolver/reload. | |
| F-08 نطاق التطبيق/متوسط | لا دفع أو شحن؛ order تعليمي. | صرح بحدود المنتج؛ صمم idempotency/payment/shipping منفصلًا. | |
| F-09 monitoring/ متوسط مشروط | values بلا chart install/version؛ Fluent Bit يتوقع kubemart-loki.logging. | ثبّت chart/release/namespace وتحقق DNS/log ingestion. | |
| F-10 تكلفة/منخفض-متوسط | CronJob كل دقيقة ويحاكي تقريرًا. | لا تنشره دائمًا أو قلل schedule/history. | |
| F-11 TLS/متوسط | example host؛ توثيق نجاح HTTP تاريخي فقط. | Domain/TLS حقيقيان واختبار خارجي/renewal. | |
| F-12 CSP/منخفض-متوسط | nginx.conf يسمح unsafe-inline بسبب JS/CSS داخل الصفحة. | انقل الملفات أو nonce/hash واختبر CSP. | |
| F-13 صيانة/منخفض | k8s/config/frontend-config.yaml يعرّف ConfigMap لا يستهلكه frontend Deployment الحالي. | احذف أو وثّق غرضه؛ تحقق من المراجع قبل الإزالة. | منخفض |

هذه findings وتوصيات، وليست إصلاحات منفذة بهذا الدليل.

# الفصل 10 — خارطة تحسين

| الأولوية | العمل | معيار قبول |
|---|---|---|
| 1 حاسم | اختبارات auth/checkout/DB وCI. | CI ينجح ويغطي DB down و401/CSRF/races. |
| 2 حاسم | إثبات NetworkPolicy وتقييد egress تدريجيًا. | المسموح ينجح والممنوع يفشل مع استمرار DNS/DB. |
| 3 حاسم | نسخ DB واستعادة موثقة. | restore ضمن RPO/RTO. |
| 4 عالٍ | Schema migration job. | job واحد مع locking وخطة rollback. |
| 5 عالٍ | SBOM/scans، images by digest، lock dependencies. | build قابل للتكرار وسياسة ثغرات واضحة. |
| 6 عالٍ | Rate limits/reset/verification/auth alerts. | اختبارات إساءة واستعادة آمنة. |
| 7 متوسط | إزالة inline CSS/JS وتقوية CSP. | CSP بلا unsafe-inline ولا كسر الواجهة. |
| 8 متوسط | تثبيت monitoring charts/rules/dashboards. | metrics/logs/alert تجريبي ظاهر. |
| 9 متوسط | API HPA/load/connection pool. | اختبار حمل آمن وقياس autoscaling. |
| 10 لاحق | idempotency/shipping/payment. | retry لا يكرر order؛ مراجعة نطاق مالي. |

## خطة أسبوعين

1. يومان: Ingress → frontend → API → DB.
2. يومان: session/cookie وSQL.
3. يومان: نشر sandbox وتحليل events/logs.
4. يومان: PVC/StatefulSet/backup.
5. يومان: probes/HPA/PDB/resources.
6. يومان: RBAC/NetworkPolicy allow-deny.
7. يومان: CI واختبارات وإجابة الأسئلة.

# الفصل 11 — اختبار المعرفة

أجب قبل الانتقال إلى الفصل التالي.

## أساسيات

س1 اختيار: وظيفة frontend Service؟ أ DB ب توجيه Pods ج إصدار TLS د بناء image.

س2 صح/خطأ: Ingress YAML يثبت الوصول العام.

س3 اشرح فرق Pod وDeployment.

س4 اختيار: من يخدم HTML؟ أ Redis ب NGINX frontend ج Postgres د PVC.

س5 صح/خطأ: كود المتجر يستخدم Redis.

## عملي

س6 رتب Ingress/controller وfrontend Service وPod.

س7 لماذا Service port 80 و8080 containerPort؟

س8 تتبع GET /api/products حتى DB.

س9 صح/خطأ: API يثق بـtotal القادم من browser.

س10 أين session token وأين يخزن DB؟

س11 لماذا WaitForFirstConsumer؟

## تشخيص

س12 frontend Ready وAPI timeout؛ اذكر 5 فحوص.

س13 API health 503 وPVC Pending؛ خطة التحقيق؟

س14 أثر غياب CPU requests على HPA CPU?

س15 صح/خطأ: liveness يفحص Postgres.

س16 Cookie لا تحفظ على HTTP؛ ما السبب والإصلاح الآمن؟

س17 policy موجودة والاتصال مسموح؛ احتمالان.

س18 أمران ImagePullBackOff وأمران endpoints.

## متقدم ومقابلة Senior

س19 لماذا SHA-256 للجلسة؟ وما الذي لا يحميه؟

س20 كيف يحمي FOR UPDATE المخزون؟ وما خطر retry؟

س21 صح/خطأ: PDB يمنع توقف الخدمة عند سقوط node.

س22 لماذا Retain ليس backup؟

س23 مخاطر DDL عند startup لنسختين API؟

س24 اذكر 3 تحسينات لمقاومة brute force.

س25 HTTPS 502 مع endpoints موجودة؛ خطة عزل حتى DB؟

س26 كيف تجعل Postgres قابلًا للاستعادة مع trade-offs؟

س27 إثبات NetworkPolicy وضبط egress بلا قطع DNS/DB؟

س28 إضافات CI وبوابة الموافقة قبل الإنتاج؟

س29 مصادر كلفة AWS وكيف تحصرها؟

س30 اختر 3 تحسينات أولى مع معيار لكل منها.

# الفصل 12 — مفتاح الإجابات

الإجابات هنا فقط لتتمكن من حل الفصل السابق أولًا.

س1: ب. Service عنوان ثابت يوجه للـPods المطابقة للselector.

س2: خطأ؛ يلزم Controller وDNS وendpoints وشبكة وشهادة.

س3: Pod وحدة تشغيل؛ Deployment controller يحافظ على replicas ويدير rollout والاستبدال.

س4: ب. NGINX frontend يخدم index.html.

س5: خطأ؛ Redis مختبر مستقل، لا اتصال له في main.py.

س6: Client→Ingress Controller يطبق rule؛ rule→Service→Pod وصف لا hop.

س7: Service port 80 يوجه إلى targetPort 8080 داخل NGINX.

س8: Ingress→frontend Service→NGINX proxy→API Service 8000→FastAPI SELECT→Postgres→JSON.

س9: خطأ؛ API يحسب total من سعر DB ويتحقق من stock.

س10: Cookie HttpOnly/Secure/SameSite بالمتصفح، digest SHA-256 وexpiry في sessions.

س11: تأخير provision/bind حتى يحدد scheduler topology المناسبة للPod.

س12: Ingress/controller، frontend endpoints، NGINX upstream/logs، API endpoints/readiness/logs، policy/CNI/DNS.

س13: PVC events وCSI/IAM/AZ؛ أصلح التخزين ثم Postgres/service/secret ثم API /health.

س14: لا يمكن حساب CPU utilization جيدًا دون request؛ HPA قد لا يتصرف.

س15: خطأ؛ /live لا يفحص DB؛ /health readiness يفعل ذلك.

س16: Secure cookie لا ترسل عبر HTTP؛ افحص DevTools/HTTPS/host/path، استخدم TLS، ولا تلغ Secure علنًا.

س17: CNI لا يطبق policies أو selector/source namespace خاطئ؛ تحقق من سلوك node-local أيضًا.

س18: describe pod وevents؛ get endpointslices وget svc -o yaml.

س19: تسريب DB لا يعطي token الصريح. مناسب لtoken عشوائي عالي entropy؛ لا يحمي سرقة cookie أو شبكة دون TLS.

س20: يقفل صفوف المنتج داخل transaction؛ الطلب التالي يرى المخزون المحدث. retry قد يكرر order؛ أضف idempotency key unique.

س21: خطأ؛ PDB يحكم بعض الإخلاءات الطوعية، لا سقوط node.

س22: Retain يمنع reclamation الآلي، لا ينشئ نسخة منفصلة ولا يثبت restore/PITR.

س23: سباق DDL، لا rollout، schema history/rollback قد يفشل؛ job واحد مع locking وexpand/contract.

س24: audit/alerts، rate limit auth وتأخير/reset/verification، lockout ورسائل لا تكشف وجود الحساب.

س25: curl، service/endpoints، DNS/TLS/Ingress events/controller، داخلي، API readiness/logs، NGINX logs، DB/PVC/secret والسياسات. لا restart عشوائي.

س26: managed DB أو backups/PITR، HA، operator مشفرة وrestore مجرب وRPO/RTO؛ managed أقل عبئًا وأعلى اعتمادًا/تكلفة.

س27: تحقق من CNI واختبر allow/deny في staging؛ اسمح DNS 53 و5432 DB→API والخدمات المطلوبة فقط.

س28: staging smoke، secrets scan، schema validation، digest، scans/SBOM، unit/integration/E2E، approval ثم قبل production وrollback.

س29: EC2/EBS/LB/NAT/data transfer/retention/replicas/CronJob؛ budgets/tags/limits وأوقف lab غير المستخدم.

س30: مفتوح. مثال: tests (CI يغطي DB/races)، policy (allow يعمل/deny يفشل)، backup restore (ضمن RTO/RPO).

# الخلاصة والمراجع

KubeMart مختبر مفيد لربط web app بـKubernetes. ممارسات الكود الجيدة تشمل digest ،Argon2 للجلسة، Cookie آمنة، حساب السعر على الخادم، قفل المخزون، وفصل liveness عن DB. أهم فجوات الإنتاج: NetworkPolicy غير مثبتة الفعالية، PostgreSQL نسخة واحدة بلا backup/restore، ولا توجد اختبارات وظيفية. الملفات تصف إعدادًا مقصودًا لا حالة cluster حية.

## معجم المصطلحات

| المصطلح | الشرح |
|---|---|
| Pod | وحدة تشغيل حاوية أو أكثر تشترك في الشبكة والتخزين. |
| Deployment | متحكم يحافظ على عدد النسخ ويدير rollout. |
| Service | اسم وعنوان ثابت يوجهان إلى Pods المطابقة. |
| Ingress | قواعد HTTP/HTTPS إلى Services، ويطبقها Controller. |
| StatefulSet | متحكم لتطبيقات تحتاج هوية أو تخزينًا مستقرًا. |
| PVC/PV | طلب تخزين / مورد التخزين الفعلي. |
| RBAC | تحديد من يملك أفعالًا على موارد Kubernetes API. |
| NetworkPolicy | تصفية حركة Pod بشرط دعم CNI. |
| HPA/PDB | توسع تلقائي / حماية من بعض الإخلاء الطوعي. |
| CNI | إضافة شبكة الحاويات داخل Kubernetes. |

## مراجع

- مستودع KubeMart
- Kubernetes Network Policies
- Kubernetes Probes
- Kubernetes StorageClass
- Kubernetes HPA

## ما لم يتحقق منه

- حالة cluster وDNS/TLS/Ingress/Pods الفعلية.
- AWS VPC/EKS/EC2 وIAM/EBS خارج repo.
- إصدارات Helm وmonitoring releases وخدمة Loki.
- نتيجة CI الحالية أو Docker/E2E على cluster.
- استعادة DB وتجربة browser حقيقية.

ملف HTML هذا مصدر قابل للتعديل وإعادة التوليد عبر `powershell -ExecutionPolicy Bypass -File output/pdf/generate.ps1`. الملف المعماري SVG منفصل. الأوامر والمخرجات المتوقعة لم تنفذ على كلاستر المستخدم.